



01/12(월) - 2주차

담당자	이예빈
유형	주간

어떤 방향으로 가면 좋을지 추가

1페이지 확장 주제제안서 (제출일 : 2014년 7월 24일)	
팀명 : 헬캣	팀원 : 강민규, 배성원, 신준권
제목 : Android Automatic Center : 안드로이드 스마트폰 알림을 이용한 원격 매크로 어플리케이션	
개요	
1. 안드로이드 스마트폰에 알림을 주는 어플리케이션과 알림 내용에 따라, 자동으로 사용자가 등록한 동작을 자동으로 실행하는 매크로 어플리케이션을 제작한다. 2. 사용자의 동작은 녹화 할 수 있고, 직접 좌표와 내용을 입력/수정할 수 있게 한다. 3. 사용자가 직접 매크로를 입력하는 과정에서 다양하게 논리 및 프로세스를 직접 짤 수 있는 인터페이스를 제공한다.	
프로세스 설정 예 :	
① '쿠광'앱의 '알림'에 '선착순'라는 단어가 '있을 경우'(/없을 경우/and/or 등.) ② 10시에 '쿠광'앱을 실행시켜 '매크로녹화1.data'를 실행한다.	
4. 위 기능까지 완성이 된다면, 사용자가 제작한 매크로를 '기종/어플리케이션/기능설명' 등의 양식으로 다른 사람들과 공유가 가능하도록 한다. 5. 사용자가 웹 서버에 접속하여 사용자의 핸드폰을 원격제어가 가능하도록 한다.	
장점	
1. 기존 안드로이드용 매크로 어플리케이션의 범용성을 확장하며, 사용자는 원하는 매크로 동작을 조건에 구애받지 않고 거의 무제한으로 입력할 수 있다. 2. 이는 스마트폰으로 게임이나 쇼핑을 많이 하는 젊은층에게 매우 유용할 앱이 될 것이다. 3. 안드로이드 운영체제를 분석하고, 사용자가 다양하게 설정할 수 있다는 점에서 '코어 테크놀로지' 적인 측면을 포함한다.	

참고 자료 및 비교 대상 1. 핸드폰 상단 알림창의 알림 내용을 이용해 제작한 안드로이드용 어플리케이션 : 후스쿨, 네이버 가계부, 카카오톡물래보기 2. 안드로이드 디바이스용 터치/키보드 입력 매크로 프로그램 : 히매크로(https://play.google.com/store/apps/details?id=com.prohiro.macro&hl=ko) 창의성 및 차별화 전략 1. 윈도우즈 운영체제에는 매크로 프로그램이 많이 배포되어 있지만, 안드로이드 운영체제에서는 거의 존재하지 않으며 기능도 한정적이다. 2. 안드로이드용 매크로 어플리케이션들은 특정 문자입력/터치입력이 반복적으로 이루어지도록 하고 있을 뿐, 특정 어플리케이션의 알림에 따라 매크로를 수행해주는 기능은 제공하지 않는다. 3. 알림을 이용한 어플리케이션 중 가장 범용성을 확보한 작품이 될 것이다. 즉, 사용자의 활용에 따라 쓰임이 무궁무진하게 확대 될 수 있다. 결론 안드로이드 운영체제 시스템을 분석해, 특정 앱의 알림 동작에 따라 터치/키입력 매크로를 수행하는 어플리케이션을 제작한다. 이는 사용자의 입력을 녹화(기록)할 수 있으며, 사용자가 자유롭게 매크로 동작 프로세스를 설정할 수 있는 ui를 제공할 것 이다. 또한, 웹 서버를 통해 접속하여 자신의 핸드폰에 대해 원격조정 서비스를 수행함으로써, 사용자의 서비스 접근성을 더 확대시킬 수 있다는 장점이 있다.

위 1페이지 확장주제제안서를 작성해야 함

- 예빈
 - 페이로드 기반 공격 문제를 만들고 사용자의 페이로드 유형에 따라 단계별 힌트를 동적으로 제공하는 구조 → XSS, SQLi, SSTI, Command Injection
 - 사전에 정의된 공격 페이로드 패턴군에 매칭
 - 행동 로그 + 문자열 특징 + 시도 흐름을 기반으로 추정 → 공격 패턴 분류

(3) 힌트는 어떻게 “단계별”로 주나?

핵심 포인트입니다.

힌트는 정답이 아니라 “다음 사고 방향”만 줍니다.

예시 (XSS 문제)

사용자의 페이로드 상태	힌트
아무 시도 없음	“입력값이 HTML에 반영되는지 확인해보세요.”
<code><script></code> 차단됨	“브라우저가 실행 가능한 다른 이벤트는 없을까요?”
<code>onerror</code> 시도	“태그가 꼭 <code><script></code> 여야 할까요?”
인코딩 시도 없음	“문자가 항상 그대로 해석될까요?”

- 논문을 쓴다면 “학습자의 공격 행동 로그를 활용한 적응형 학습 제어 시스템”
 - 단순 정답 기반 위게임의 한계 지적
 - 공격 시도 과정 자체를 학습 신호로 사용
 - 힌트 제공 시점, 강도의 자동 조절
 - 초보자의 이탈 감소 효과
- 특허의 관점에서는
 - 입력 페이로드 로그 수집
 - 공격 유형 분류
 - 실패/우회 시도 판단
 - 힌트 단계 자동 결정
 - 다음 문제 난이도 추천
- 이외의 진행해야 할 목표

- aws 배포
- 버그 수정
- 새로운 문제 유형 추가
 - xss
 - sqli
 - ai 보안
- 문제 생성시 선택한 이미지 사용하여 생성
- 다인
 - 새로운 유형의 문제 추가
 - AI 아닌 분야에 대해서도 보안 문제가 있으면 좋을 것 같다는 생각
 - AI 분야 중에서는 지금까지 LLM에 대한 보안 문제만 다뤘기 때문에 이미지나 다른 모델에 대한 보안 문제도 추가하면 좋을 것 같음
 - 사용자가 문제를 올릴 수 있는 어떤 게시판? 이 있으면 좋을 것 같음
(일반 사용자가 만든 문제도 올릴 수 있도록)
 - 문제를 올리는건 관리자가 검증한 다음 올리는 시스템
 - 문제에 대한 의견? 댓글을 남길 수 있는 시스템
 - 해당 내용을 바탕으로 보완할 수 있도록 하기 위한 시스템
 - Ban 관련 내용도
- 민서
 1. 새로운 문제 추가 ✓
 - 기존에 있는 문제 유형은 난이도별로 문제를 다양화?하면 좋겠다 ✓
 - 새로운 문제 유형 추가 ✓
 - SQLi ✓
 - XSS ✓
 - SSRF
 - 서버가 url 받아서 서버가 대신 요청해주는 기능이 있을 때 공격자가 그 url에 내부 주소를 넣어서 서버가 내부망/로컬로 요청하게 만들
 - 외부에서 접근 가능한 웹 서버의 취약 파라미터를 통해 내부 서버에 요청을 보내고 결과를 받아낼 수 있음
 - 내부 대역으로의 요청, url 인코딩 우회 시도 등 방법
 - 파일 제공형 문제는 어떨지? 주어진 서버에서 문제를 할 수 있다는 게 장점인 서비스이긴 한데 서버 링크 대신 파일 다운로드 가능한 링크를 넣으면 기존 장점이 그렇게 위배될 것 같지는 않음. ✓
 - (안 해도 되지만 문제 유형 다양성을 위해 한 번 말해봄) ✓

- 로그/포렌식
- 리버싱
- 크립토

2. 완성 후 배포 - 이번엔 서버 올리기 성공하자..... ✓

3. 로그 기능 개선 - 예빈 말대로 ... BAN을 하기 위한 기준을 명확히 작성하는 것이 좋을 듯 ✓

- 목적 : 사용자 계정 보호, Hackahoy서비스 보호 ✓
- 문제 상황 발생 시 바로 ban 하지 말고 사전 경고 기능 추가 ✓
 - 문제 상황 발생 → 사용자 경고 → 제한 → ban 및 영구정지 ✓
 - 갑자기 생각이 났는데 관리자가 ban하는 대신 특정 조건을 위배하면 자동으로 해당 계정 ban 시키기?가 더 문서 작성할 때 좋을 것 같네여 ✓
- [사용자 로그 기반 Rule] - 위배 시 경고 로직 실행 ✓
 - 동일 계정에서 특정 시간 내 로그인 시도를 많이 할 경우
 - 동일 계정에서 특정 시간 내 문제 시도 횟수가 비정상적으로 많을 때
 - 동일 계정에서 특정 시간 내 요청 횟수가 많은 경우
 - 존재하지 않는 경로에 대해 특정 시간 내 요청 횟수가 많은 경우
 - /admin 등 사용자가 사이트 경로 직접 입력해서 접속 시도하는 경우
 - 서로 다른 계정들의 특정 시간 내 로그인 실패 횟수가 많은 경우 (credential stuffing?)
 - 서로 다른 계정들이 특정 시간 내 동일 문제를 빠르게 정답을 맞힌 경우 (플래그 공유 방지)
 - 위 내용들 적용한다면 특정 시간과 횟수를 구체적으로 각 경우에 대해 정해야 함!! ✓
 - 그리고 될 수 있으면 동일 계정 말고도 동일 IP에 대해서도 적용하면 좋은데 이게 가능한건지? 잘 모르겠다. ✓
 - 된다면 IP는 많은 사람들이 같이 사용하거나, 공격자의 IP가 자주 바뀔 수 있으니 "IP+계정", "IP+user agent+요청 패턴" 등 조합해서 많이 사용한다고 함 ✓

4. 추가 자잘한 기능들 - 캡스톤 1 하면서 생각해둔 것들 ✓

- 배 이미지 추가
- gemini 등 AI 연결해서 사용자 문제 등록 시 [섬 이미지/문제 배경화면/힌트 아이콘] 원하는 방향으로 생성 가능하게 하기 ✓
- 문제가 추가되면 메인 화면에서 보이는 핀의 개수가 3개가 아니라 그 이상으로 늘어나야 함
- 문제 푼 거에 따라 다음 레벨업까지 얼마나 남았는지 게이지 표시하기 ✓
 - 상하단 바 이용 or 마이페이지 내부 표시
- solved 내역 확인 기능 ✓
- 사용자 간 레벨 기준으로 랭킹 → 사용자 흥미 높이기,, ✓
- 힌트 추가 기능

- 만약 DB 상에서 사용자가 문제 해결한 내역을 삭제하면 강제로 레벨 다운그레이드 시키기
 - 이거는 제가 1 구현하면서 테스트 할 때 불편했던 부분인데 이게 필요한지는 잘 모르겠습니다. 테스트 말고 실제 서비스 사용하고 운영할 땐 필요 없을 것 같.. 일단 놔둘게요
- 민영
 - 교육 효과를 높이는 방향으로
 - AI 기반 학습 프로그램 → 사용자가 시도한 방법, 입력한 방법에 따라 난이도가 변화하는 '적응형 문제' 도입
 - 정답 여부, 풀이 시간, 반복 오답 패턴을 분석해 난이도와 힌트량을 조절하고, 이를 통해 각자 수준에 맞는 문제를 제공
 - 초보자 중에서도 진짜 생 초보한테는 진입장벽을 더 완화
 - 약간 지식이 있는 사람에게는 좀 더 도전할 걸 제공
 - 수준별 학습 흥미와 효과를 증가시키기
 - 난이도 조절 예시
 - 특정 카테고리에서 빠르게 여러 문제를 풀었다면, 다음 문제는 더 복합적인 취약점이 포함된 문제를 제시
 - 같은 유형에서 일정 횟수 이상 틀리면 추가 힌트 제공, 부분적으로 익스플로잇 코드를(이건 코드를 짜서 풀어야 하는 문제를 만든다면...?) 생성해주는 방식
 - 사용자의 답변을 보고 참고하면 좋은 키워드, 개념을 피드백해주는 방식
 - 조정된 난이도에 따라 점수를 다르게 부여해도 좋을 듯
 - 논문은 테스트 운영 해보고 이런 교육이 얼마나 효과적인지..?
 - 사용자의 참가 전후 지식 변화, 난이도의 적절성 등을 설문
 - 실제 문제 풀이 성과 확인
 - 해결한 문제 수, 카테고리별 성공률, 평균 풀이 시간, 제시된 힌트 수 차이 등을 비교
 - 논문을 '위게임'으로 검색하면 전쟁 관련 게임/군사 작전 관련 내용만 제시되는데... 레퍼런스를 많이 못 찾았습니다 ππ 죄송합니다...
 - <https://www.studocu.vn/vn/document/hoc-vien-cong-nghe-buu-chinh-vien-thong/cong-nghe-phan-mem/effectiveness-of-ctf-education-measuring-learning-outcomes-in-cyber-security/140480157> // Jeopardy 스타일 CTF(여러 분야 보안 문제를 문제판 형태로 늘여놓고 플래그 제출해서 점수 얻는 형식) 교육 효과에 관한 논문(어떤 지식, 태도를 길러주는지, 그 학습 효과를 어떻게 측정할 수 있는지 프레임 워크, 체크리스트 제안)
 - https://www.usenix.org/system/files/conference/ase17/ase17_paper_trickel.pdf // CTF-as-a-service for Security Education에 관한 논문 (대규모 CTF를 열 수 있도록 클라우드 기반 CTF 플랫폼을 설계, 구현하면서 얻은 교훈..에 관한 내용)
 - 프로젝트의 매력도를 높이는 방향!!
 - 전문성이 느껴지게 기능 심화, 타겟 세분화 등

- 배포 및 운영까지(며칠 정도라도)
 - 가능하다면 공모전도 알아보면 좋을 듯
- Todo
 - 기능 완성도 보강
 - aws 문제 해결
 - 코드 개선(하드코딩된 부분 제거 등)
 - 에러 로그 수집 및 대응 절차 마련
 - README, 운영문서 정리

• 지선

서버 올리는 건 당연히 한다고 생각하고 작성했습니다.

1. 개인화 된 AI 튜터 추가

지금의 힌트는 정적으로 등록되어 있는 힌트가 다임.

사용자가 힌트를 달라고 하면 AI 튜터가 사용자의 진행 상황이나 입력한 페이로드를 분석해서 문제 풀이의 방향을 제시해주는 방식

2. 사용자의 문제 풀이 시각화 (로그 대시보드 추가)

보통 보안 공부할 때 공격하면 그냥 공격 됐구나~ 정도만 알고 원리를 제대로 파악하지 못하는 경우가 있음.

이걸 좀 개선해서 SQL injection을 시도하면 DB 로그나 웹 서버 로그가 어떻게 찍히는지 실시간으로 보여주면 어떨까

사용자가 시도하려 했던 문제 풀이가 어떤 경로로 들어와서 어떻게 차단되었는지, 혹은 어떻게 풀렸는지 시각화 해주는 형식

→ 이를 통해 공격/방어 관점을 모두 학습할 수 있지 않을까

3. AI 기반 치팅 탐지 및 난이도 분석

사용자가 푼 문제를 AI가 분석해서 Write-Up을 바로 보고 풀었는지 풀이 시간+페이로드 등을 가지고 로그 분석

사용자들의 평균 풀이 시간, 포기율 등을 가지고 난이도 분석

4. 추가 자잘한 기능

- 문제 삭제 기능 추가
- 섬 이미지 변경 기능 (시간 남으면 추가하면 좋을 듯)
- 추가한 문제에 힌트 추가 기능 (기존엔 문제 추가하면 힌트 추가가 안됐음)
- 관리자 뿐만 아니라 사용자도 문제를 추가할 수 있으면 어떨까 (문제의 다양성 확보)
 - +) 관리자가 UI에서 수동으로 문제 입력하는 거 말고 git 레포 주소 입력하면 Hackhoy 서버가 자동으로 빌드하고 배포하는 형식으로 수정해도 괜찮을 것 같음.
- 좀 더 다양한 문제 유형 추가

- 난이도 표기

기존 입문자 친화적에서 사용자가 점점 더 발전할 수 있도록 난이도 표기 + 다양한 난이도의 문제 추가

- **aws 배포**

- 자잘한 버그 수정

- 기존 기능 구체화

- **Ban 기준**

- 사용자가 새로운 문제 추가하기

- **새로운 기능 추가**

- **ai 기반 학습 프로그램 → 문제 추천**

- **페이로드 분석 → 힌트 제공**

- ai 치팅 탐지 및 난이도 분석

- 문제 풀이 시각화

- 게시판 기능
-

aws 배포

새로운 유형 문제 추가

ai 학습 프로그램

ban 기준

→ 특허랑 공모전에 대해서 좀 조사를 해야될 거 같아여

14일 12시 40분인데 → 교수님 1시에 끝 → 특허랑 공모전 나가고 싶은거에 대해서 조사해서 엘베 토크(10분 내외)